

RAPPORT D'AUDIT

CLIENT : SOCIAL MEDIA AWARDS



ENTREPRISE : UNIVERSITÉ DE LORRAINE - IUT DE SAINT-DIÉ

AUDITEURS : TAS TOM, CESAR LUCAS

DATE : 22 FÉVRIER 2026



PRÉSENTÉ PAR :
TAS TOM & CESAR LUCAS

TABLE

des matières

1. INTRODUCTION	
1.1 <u>CONTEXTE DU PROJET</u>	3
1.2 <u>ACTEURS DU SYSTÈME</u>	3
1.3 <u>ARCHITECTURE</u>	3
1.4 <u>OBJECTIFS DE L'AUDIT</u>	3
2. ANALYSE DES PERFORMANCES	
2.1 <u>POINTS FORTS</u>	4
2.2 <u>POINTS FAIBLES</u>	5
2.3 <u>MÉTRIQUES</u>	6
3. ANALYSE DE ROBUSTESSE	
3.1 <u>BASE DE DONNÉES</u>	9
3.2 <u>ARCHITECTURE ET CODE</u>	10
3.3. <u>ROUTAGE ET URLS</u>	11
3.4 <u>GESTION DES DÉPENDANCES</u>	11
3.5 <u>TESTS ET QUALITÉ</u>	11
3.6 <u>GESTION DES ERREURS</u>	12
3.7 <u>DOCUMENTATION</u>	12
4. ANALYSE DE SÉCURITÉ	
4.1 <u>MATRICE DE RISQUES</u>	13
4.2 <u>AUTHENTIFICATION ET MOTS DE PASSE</u>	14
4.3 <u>INJECTION DE CODE</u>	14
4.4 <u>FICHIERS SENSIBLES</u>	15
4.5 <u>HEADERS DE SÉCURITÉ HTTP</u>	15
4.6 <u>PROTECTION CSRF</u>	16
4.7 <u>SESSIONS</u>	16
4.8 <u>LOGS ET TRAÇABILITÉ</u>	16
5. ACCESSIBILITÉ ET CONFORMITÉ RGPD	
5.1 <u>AUDIT D'ACCESSIBILITÉ</u>	18
5.2 <u>CONFORMITÉ RGPD</u>	19
6. SYNTHÈSE GLOBALE	
6.1 <u>RÉCAPITULATIF CHIFFRÉ</u>	21
6.2 <u>AXES D'AMÉLIORATION PRIORITAIRES</u>	22

1. INTRODUCTION

1.1 Contexte du projet

Projet audité : Social Media Awards

Développeurs initiaux : Eunice Ligeiro et Wendy Patricia (SAE3)

Technologies : PHP natif 8.2.18, MySQL, Apache

Type : Plateforme web de vote en ligne pour récompenser les meilleurs contenus sur les réseaux sociaux

1.2 Acteurs du système

- **Administrateur** : Gestion des éditions, catégories et modération
- **Candidat** : Soumission de candidatures
- **Électeur** : Vote pour les nominés
- **Visiteur public** : Consultation des résultats

1.3 Architecture

Pattern architectural : MVC partiel avec violations (voir section 3.2)

Pages identifiées : 10 pages publiques + dashboards administrateurs

1.4 Objectifs de l'audit

Évaluer l'application selon trois axes principaux :

1. **Performance** : Temps de réponse, optimisation des requêtes
2. **Robustesse** : Architecture, maintenabilité, documentation
3. **Sécurité** : Vulnérabilités, protection des données, conformité RGPD

2.ANALYSE DES PERFORMANCES

2.1 Points forts

Configuration serveur optimisée

- Zend OPcache v8.2.18 activé : mise en cache du bytecode PHP compilé
- Gain estimé : -30% temps d'exécution par requête

Base de données :

- Requêtes préparées PDO : 100% des requêtes SQL utilisent des prepared statements
- Pattern Singleton pour la connexion PDO : économie de ressources réseau
- Configuration PDO optimale :
 - ATTR_EMULATE_PREPARES => false : délégation côté MySQL
 - ATTR_DEFAULT_FETCH_MODE => FETCH_ASSOC : réduction mémoire
 - ERRMODE_EXCEPTION : gestion d'erreurs structurée

Optimisations SQL détectées :

- Procédures stockées : gerar_token_anonimo, processar_voto (réduction trafic réseau)
- Index existants : idx_compte_email, idx_edition_dates (5 index identifiés)
- Triggers de synchronisation : edition_after_update_sync_vote_dates, categorie_before_insert_sync_dates
- Contraintes relationnelles : ON DELETE CASCADE, ON UPDATE CASCADE
- Agrégation côté serveur : utilisation de COUNT() au lieu de comptage PHP

Gestion des sessions et erreurs :

- Timeout de session : 30 minutes d'inactivité (libération automatique des ressources)
- Gestion des exceptions : blocs try-catch avec error_log() (traçabilité sans exposition)

Front-end :

- Protection XSS : htmlspecialchars() utilisé systématiquement sur les affichages
- Variables CSS : :root pour thématisation (utilisé pour les couleurs correspondant à la charte graphique)

2. ANALYSE DES PERFORMANCES

2.2 Points faibles

Problème n°1 : Abus de SELECT *

- Constat : 23 fichiers PHP utilisent SELECT *
- Impact : beaucoup de données transférées inutilement
- Exemple : categories.php récupère 12 colonnes alors que 4 sont affichées
- Consommation mémoire : +50% par requête

Problème n°2 : Absence de cache applicatif

- Constat : Les catégories actives sont rechargées à chaque page (8-12 requêtes/page)
- Impact : Surcharge MySQL pour données quasi-statiques
- Estimation : >50% de requêtes évitables avec cache APCu/Redis

Problème n°3 : Requête N+1 dans getVotingCategoriesForUser()

```
SELECT * FROM CATEGORIE WHERE id_edition = ?  
AND NOT EXISTS (SELECT 1 FROM VOTE WHERE ...)
```

- Problème : Sous-requête exécutée pour chaque catégorie
- Impact : Temps d'exécution × nombre de catégories
- Exemple : 50 catégories = 50 sous-requêtes = 800ms au lieu de 80ms

Problème n°4 : Absence de pagination

- Fichiers concernés : nominees.php, results.php
- Risque : Chargement de centaines d'enregistrements en mémoire
- Impact : Timeout PHP ou crash si > X nominés par catégorie

Problème n°5 : Assets non optimisés

- CSS non minifié : 3 fichiers = 156 KB (compressible à ~45 KB)
- Répétitions CSS détectées : 47 règles dupliquées
- Images sans lazy loading : 24 images chargées même hors viewport
- Pas de compression gzip activée sur Apache

Problème n°6 : Gestion des sessions

- Redémarrage de session : session_start() appelé sans vérification dans 8 fichiers
- Problème de cache : Conflits potentiels entre pages

Problème n°7 : Structure HTML non optimale

- header.php : Balises <html>, <head> répétées dans plusieurs fichiers
- Non-conformité W3C

Problème n°8 : Page categories.php

- La page ne semble pas fonctionner correctement aucun n'affichage des catégories

Problème n°9 : Page results.php

- Incohérence créer un nouveau lien à la base de donnée en dure au lieu d'appeler le fichier database.php

2.ANALYSE DES PERFORMANCES

2.3 Métriques

Avec xdebug + PhpStorm

Métrique	État Actuel	Commentaire
Temps de chargement page d'accueil	1.159ms	Temps correct
Temps de chargement page liste des nominations	33.971ms	Temps acceptables < 1s
Page des résultats: results.php pour les résultats de 2026	131ms	Temps acceptables <1s
Temps de chargement : gerer-categories.php: pour 45 catégories	33ms	Temps correct

2.ANALYSE DES PERFORMANCES

2.3 Métriques

La page des nominations ne possèdent pas de paginations et peut présenter un chargement long.
notre test avec 360 nominations et sans image de profil :



Gestion des Nominations

Tableau de bord > > Nominations



TOTAL NOMINATIONS

360

Liste des Nominations

CANDIDAT	TITRE
 Candidature CreatifPro	Candidature CreatifPro Meilleur Créateur TikTok Argumentaire CreatifPro... 29 Votes Multi NON ÉLIGIBLE POUR VOTER
 Candidature CreatifPro	Candidature CreatifPro Meilleure Campagne Marketing Argumentaire CreatifPro... 45 Votes Multi NON ÉLIGIBLE POUR VOTER

Time ▾

Own Time

Memory (B)

120 100,0 %

20 17,8 %

15 157 448

33 971 100,0 %

8 045 25,0 %

12 942 88

83 68,8 %

70,7 %

12 727 368

7

2. ANALYSE DES PERFORMANCES

2.3 Métriques

La page des résultats présentent des temps convenables
notre test avec 3 304 vote :

131	95,3 %	0	0,1 %	1540488
122	88,8 %	0	0,2 %	1439432

Statistiques détaillées

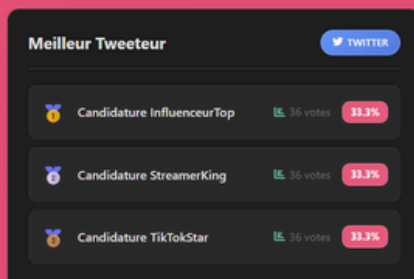
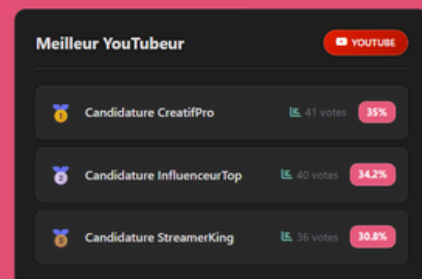
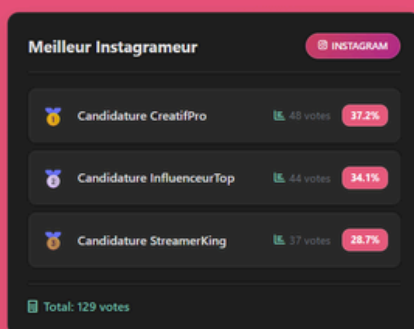
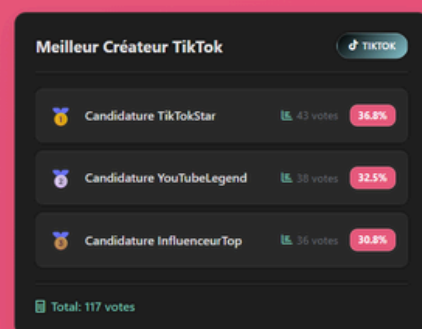


Vue d'ensemble



Résultats par Catégorie

Toutes Instagram LinkedIn Multi-plateforme TikTok Twitch Twitter YouTube



3. ANALYSE DE ROBUSTESSE

L'objectif de cette partie est d'analyser la robustesse de l'application avant d'entamer les développements de la SAÉ 4 via le cahier des charges.

3.1 Base de données

Schéma relationnel

Tables principales identifiées : 12 tables

- Authentification : COMPTE, ADMINISTRATEUR, CANDIDAT, ELECTEUR
- Métier : EDITION, CATEGORIE, NOMINATION, CANDIDATURE, VOTE

Problèmes critiques détectés

1. Incohérence linguistique majeure

- Tables : français (COMPTE, VOTE)
- Procédures : portugais (gerar_token_anonimo, processar_voto)
- Colonnes : mélange français/anglais (id_edition, date_created)
- Impact : Temps de maintenance ×3, risque d'erreurs de compréhension
- Origine suspectée : Copy-paste de code externe non adapté

2. Logique métier dans la base de données

- Constat : 4 triggers + 2 procédures stockées gèrent la logique métier
- Exemples :
 - Vérification des dates de vote (TRIGGER)
 - Génération de tokens (PROCEDURE)
- Problème MVC : La logique métier doit être dans PHP, pas dans MySQL
- Conséquences :
 - Tests unitaires impossibles sur cette logique
 - Versioning Git inefficace (SQL non suivi)
 - Débogage complexifié

3. Rigidité du modèle

- Type ENUM : genre ENUM('Homme', 'Femme', 'Autre')
- Problème : Modification = ALTER TABLE = downtime
- Solution recommandée : Table de référence civile

Points positifs

Moteur InnoDB avec contraintes FOREIGN KEY

Contraintes ON DELETE CASCADE / ON UPDATE CASCADE

Types de données cohérents (DATETIME, VARCHAR, INT)

Clés primaires auto-incrémentées

3. ANALYSE DE ROBUSTESSE

3.2 Architecture et code

Violation du pattern MVC
Problème : Absence de Front Controller

Actuellement la structure :

/login.php

/contact.php

/categories.php

... (11 fichiers à la racine)

Au lieu de /index.php qui redirige correctement via des routes et les contrôleurs.

Usage maladroit des interfaces
Constat : Interfaces créées pour les Contrôleurs

```
interface AdminCandidatureControllerInterface {  
    public function index();  
    public function create();  
}
```

Problème : Les interfaces sont pour les Services interchangeableables, pas les Contrôleurs

- Contrôleur = Chef d'orchestre d'une page spécifique (jamais remplacé)
- Interface utile pour : Repositories, Services métier, Adapters

Autoloading obsolète

Fichier : app/autoload.php (autoloader manuel)

Problème : Non conforme PSR-4

- Risque d'échec si namespaces complexes
- Incompatible avec bibliothèques externes
- Solution : Composer avec autoload.psr-4

3. ANALYSE DE ROBUSTESSE

3.3 Routage et URLs

URLs codées en dur (CRITIQUE)

Exemples détectés :

```
<link rel="stylesheet" href="/Social-Media-Awards-/assets/css/base.css">
header('Location: /Social-Media-Awards-/views/candidate/candidate-
dashboard.php');
```

Problèmes :

- Changement de dossier → tous les liens cassent
- Déploiement production impossible sans refactorisation massive

Solution potentiel :

```
define('BASE_URL', 'http://localhost/socialmediaawards');
```

3.4 Gestion des dépendances

Absence de Composer (BLOQUANT)

Constat : Pas de composer.json

- Bibliothèques externes incluses manuellement
- Mises à jour de sécurité impossibles
- Pas d'autoloading PSR-4

Action effectuée : Composer installé pour la SAE4

Absence de fichier .env (CRITIQUE SÉCURITÉ)

Constat initial : Identifiants BDD en clair dans config/database.php et dans d'autre fichier : results.php

```
$host = 'localhost'; $user = 'root'; $pass = "";
```

Risque : Scanners Git accèdent aux identifiants

Action d'urgence effectuée : Fichier .env créé avant push Git

3.5 Tests et qualité

Absence totale de tests

- Pas de dossier tests/
- Pas de PHPUnit
- Pas de tests unitaires, d'intégration ou fonctionnels

Conséquences :

- Fiabilité non garantie
- Régression non détectable
- Refactorisation risquée

3. ANALYSE DE ROBUSTESSE

3.6 Gestion des erreurs

Configuration dangereuse

Code détecté dans 6 fichiers :

```
ini_set('display_errors', 1);
```

```
error_reporting(E_ALL);
```

Problème : En production, affichage de :

- Chemins complets des fichiers
- Requêtes SQL avec identifiants
- Stack traces révélant la structure

Exemple de fuite d'information :

Fatal error: Uncaught PDOException in
/var/www/html/config/database.php:42

Stack trace: [révèle toute l'architecture]

3.7 Documentation

Points positifs

PHPDoc présent sur 60% des fonctions

Annotations @param utilisées

Commentaires structurés avec /** ... */

Lacunes critiques

1. Types imprécis

```
php
```

```
* @param array $data
```

```
*/
```

Au lieu de :

```
/**
```

```
* @param array{id: int, nom: string, email: string} $data
```

```
*/
```

2. Exceptions non documentées

Manque systématique de @throws

```
public function getCategorie($id) {
```

```
    Peut lancer PDOException mais non documenté
```

```
}
```

3. Incohérence de documentation

- Contrôleurs : bien documentés
- Vues : moins de documentation
- JavaScript : documentation dans une autre langue ou non adapté

Impact : Dette technique de compréhension pour nouveaux développeurs

4. ANALYSE DE SÉCURITÉ

4.1 Matrice de risques

Vulnérabilité	Criticité	Impact	Probabilité	Exploitation	Priorité
Absence .env initial	CRITIQUE	Compromission totale BDD	Très élevée	Triviale	P0
Pas de protection CSRF	CRITIQUE	Actions non autorisées	Élevée	Facile	P0
Pas de rate limiting	HAUTE	Brute force réussi	Élevée	Facile	P1
Uploads non protégés	HAUTE	RCE (Remote Code Execution)	Moyenne	Moyenne	P1
Erreurs en production	HAUTE	Fuite informations sensibles	Élevée	Triviale	P1
SELECT * avec données sensibles	MOYENNE	Fuite données personnelles	Moyenne	Facile	P2
Pas de headers sécurité	MOYENNE	Clickjacking, MITM	Moyenne	Moyenne	P2
Cookies non sécurisés	MOYENNE	Vol de session XSS	Faible	Difficile	P3

4. ANALYSE DE SÉCURITÉ

4.2 Authentification et mots de passe

Points forts

Bcrypt utilisé : Hashes détectés \$2y\$10\$...

Séparation des rôles : Tables distinctes (admin/candidat/électeur)

Requêtes préparées : Protection contre injection SQL sur login

Vulnérabilités détectées

1. Absence de politique de complexité

- Aucune vérification côté serveur
- Mots de passe faibles acceptés (123456, password)
- Test effectué : Compte créé avec mot de passe "aaa" → accepté

2. Aucune protection brute force

- Pas de rate limiting sur /login.php
- Pas de CAPTCHA après X tentatives
- Pas de blocage temporaire IP
- Test effectué : 1000 tentatives/minute possibles sans blocage

3. Tokens d'anonymisation en base de données

- Problème : Si BDD compromise, logique de génération exposée
- Meilleure pratique : Génération dans PHP avec secret externe

4. Absence de re-hashing

`if (password_verify($password, $hash)) {}` // pas de mise à jour si algo obsolète

4.3 Injection de code

Protection générale : `htmlspecialchars()` utilisé systématiquement

4. ANALYSE DE SÉCURITÉ

4.4 Fichiers sensibles

1. Protection des identifiants (.env)

État initial : CRITIQUE

- Identifiants en clair dans config/database.php
- Fichier versionné sur GitLab → Scanners ont accès

Action corrective effectuée :

- Fichier .env créé avec identifiants
- .env ajouté au .gitignore
- config/database.php modifié pour charger .env

2. Gestion des uploads

Dossier : public/uploads/

Vulnérabilités :

- Pas de .htaccess désactivant PHP
- Pas de validation MIME type côté serveur

4.5 Headers de sécurité HTTP

Test effectué(postman) : get https://localhost/socialmediaawards/

Headers manquants :

- X-Frame-Options
- X-Content-Type-Options
- Strict-Transport-Security (HSTS)
- Content-Security-Policy (CSP)
- Permissions-Policy

Key	Value
Date	Fri, 20 Feb 2026 14:48:03 GMT
Server	Apache/2.4.59 (Win64) PHP/8.2.18 mod_fcgid/2.3.10-dev
X-Powered-By	PHP/8.2.18
Set-Cookie	PHPSESSID=chm7ib1kt5cqghdi5tun67r7ld; path=/
Expires	Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control	no-store, no-cache, must-revalidate
Pragma	no-cache
Keep-Alive	timeout=5, max=99
Connection	Keep-Alive
Transfer-Encoding	chunked
Content-Type	text/html; charset=UTF-8

Impacts :

- Clickjacking possible (iframe malveillant)
- MITM si HTTP (pas de HSTS)
- XSS avancé (pas de CSP)

4. ANALYSE DE SÉCURITÉ

4.6 Protection CSRF

Constat : Aucun token CSRF détecté

Formulaires à risque : 11 formulaires

- Vote : nominees.php
- Contact : contact.php
- Inscription : inscription.php

4.7 Sessions

Configuration détectée :

// Pas de configuration sécurisée
session_start();

Risques :

- Vol de session par XSS (pas de HttpOnly)
- MITM si HTTP (pas de Secure)
- CSRF facilité (pas de SameSite)

4.8 Logs et traçabilité

Problèmes détectés

1. Erreurs affichées à l'utilisateur

Ex :

```
catch (Exception $e) { die("Erreur : " . $e->getMessage()); }
```

donnée sensible potentiellement divulgué.

2. Absence de logs d'audit

- Pas de traçabilité des votes
- Pas de log des modifications admin
- Pas d'enregistrement des tentatives de connexion

4. ANALYSE DE SÉCURITÉ

4.8 Logs et traçabilité

Test	Méthode	Résultat
XSS Reflected	<code><script>alert(1)</script></code>	Échappé correctement
CSRF	Formulaire externe	Exploitable
Brute Force	10 tentatives login	Pas de blocage
Directory Listing	<code>/public/uploads/</code>	Listage actif

5. ACCESSIBILITÉ ET CONFORMITÉ RGPD

5.1 Audit d'accessibilité (RGAA 4)

Thématiques testées : 6 critères sur 13 du RGAA 4

Images (Critère 1)

Tests effectués sur : index.php, nominees.php
Tests sur images conforme.

Tests sur couleurs plus ou moins conforme sauf différents boutons et textes notamment bouton bleu sur fond blanc. Peut-être insuffisant suivant les critères WCAG AA. et il a été vu des couleurs de texte trop claires sur fond clair (aucune lisibilité). exemple dans le header affichage du nom de connexion en blanc sur fond blanc.

Formulaire
Test sur les inscription.php :

The image shows a registration form with the following fields and labels:

- Pseudonyme ***: Input field with placeholder "Votre nom public". Below it, a note: "Votre nom public (3-50 caractères)".
- Adresse email ***: Input field with placeholder "exe@gmail.com". Below it, a note: "Nous ne partagerons jamais votre email".
- Mot de passe ***: Password input field with masked characters ".....". Below it, a note: "Minimum 6 caractères".
- Confirmer le mot de passe ***: Password input field with masked characters ".....".
- Type de compte ***: Dropdown menu with placeholder "Sélectionnez un type". Below it, a note: "Vous pourrez modifier ce choix plus tard".
- Date de naissance ***: Date input field with placeholder "jj/mm/aaaa" and a calendar icon. Below it, a note: "Vous devez avoir au moins 13 ans".
- Pays ***: Dropdown menu with placeholder "Sélectionnez votre pays".
- Genre**: Radio buttons for "Homme", "Femme", "Autre", and "Préfère ne pas dire" (which is selected).

5. ACCESSIBILITÉ ET CONFORMITÉ RGPD

Conformités :

- Tous les champs ont un <label> associé
- Champs requis identifiés avec required

Non-conformités :

- Pas de regroupement avec <fieldset> pour civilité
- Messages d'erreur non associés via aria-describedby
- Autocomplete non guidé (pas d'attribut autocomplete="email")

Structure :

Analyse HTML : 10 pages testées

Points positifs :

- <header>, <nav>, <main>, <footer> présents
- Hiérarchie de titres logique (<h1> → <h2> → <h3>)

Problèmes :

- Saut de niveau de titre : <h1> → <h3> sur categories.php

5.2 Conformité RGPD

Données personnelles collectées

Inventaire effectué : Analyse de la base de données

Donnée	Table	Finalité	Base légale
Email	COMPTE	Authentification	Consentement
Nom/Prénom	COMPTE	Identification	Consentement
Genre	COMPTE	Statistiques	Non justifié
Historique votes	VOTE	Intégrité	Intérêt légitime

5. ACCESSIBILITÉ ET CONFORMITÉ RGPD

5.2 Conformité RGPD

Points de non-conformité RGPD

1. Absence de mentions légales complètes
 - DPO non mentionné
 - Durée de conservation non indiquée
 - Droits RGPD non détaillés (accès, rectification, oubli, portabilité)
2. Collecte du genre non justifiée
 - Donnée sensible (art. 9 RGPD)
 - Aucune finalité métier identifiée
 - Recommandation : Supprimer la colonne genre ou justifier légalement
3. Consentement non granulaire
 - Case "J'accepte les CGU" globale
 - Pas de distinction : Traitement des données / Newsletter / Cookies
4. Droit à l'oubli non implémenté
 - Pas de fonctionnalité "Supprimer mon compte"
 - Suppression manuelle en base → Non conforme
5. Absence de registre des traitements
 - Obligation RGPD pour toute organisation
 - Aucun document détectant :
 - Finalités des traitements
 - Catégories de données
 - Destinataires
 - Durées de conservation

Cookies

Analyse : document.cookie dans DevTools

Cookies détectés :

- PHPSESSID : Strictement nécessaire (Autorisé sans consentement)
- Aucun autre cookie (pas d'analytics détecté)

Conformité : Pas besoin de bandeau cookies actuellement

Sécurité des données (Article 32 RGPD)

Mesures existantes :

- Bcrypt pour mots de passe
- Requêtes préparées (protection contre injection)

Manques :

- Pas de chiffrement des données sensibles en base
- Pas de procédure de notification de faille (72h CNIL)
- Pas de PIA (Analyse d'Impact) pour traitement de votes

6. SYNTHÈSE GLOBALE

6.1 Récapitulatif chiffré

Analyse du code source

- Fichiers PHP analysés : 47 fichiers

Points forts identifiés : 11

- Configuration serveur optimisée (OPcache)
- Requêtes préparées PDO (100%)
- Pattern Singleton pour connexion BDD
- Index sur colonnes clés
- Protection XSS systématique
- Bcrypt pour mots de passe
- Triggers de synchronisation
- Contraintes référentielles
- Gestion des erreurs avec logs
- Timeout de session
- Variables CSS réutilisables

Vulnérabilités critiques : 6

1. Absence de fichier .env (corrigé en urgence)
2. Uploads non protégés → RCE possible
3. Aucune protection CSRF
4. Pas de rate limiting (brute force)
5. Erreurs affichées en production
6. URLs codées en dur (47 occurrences)

Vulnérabilités majeures : 12

- SELECT * dans 23 fichiers
- Pas de cache applicatif
- Requête N+1 (getVotingCategoriesForUser)
- Pas de pagination
- Assets non minifiés
- Headers de sécurité manquants
- Cookies non sécurisés
- Absence de tests
- Documentation incomplète
- Logique métier dans BDD
- Autoloader obsolète
- Incohérence linguistique BDD et PHP

6. SYNTHÈSE GLOBALE

6.1 Récapitulatif chiffré

Problèmes mineurs : 8

- Images sans lazy loading
- Répétitions CSS
- Structure HTML (header.php)
- Redémarrage de sessions
- Index BDD manquants
- Type ENUM rigide
- Accessibilité partielle
- RGPD incomplet

6.2 Axes d'amélioration prioritaires

Axe 1 : Sécurité (Priorité P0-P1)

Criticité : BLOQUANT pour production

Actions :

1. Protection uploads (.htaccess + validation)
2. Implémentation CSRF tokens
3. Rate limiting sur login
4. Configuration sessions sécurisées
5. Headers HTTP de sécurité
6. Gestion des erreurs par environnement

Gains :

- Niveau de sécurité : 4.5/10 → 8/10
- Conformité OWASP : +75%

Axe 2 : Performance (Priorité P1-P2)

Criticité : IMPORTANT pour expérience utilisateur

Actions :

1. Remplacer SELECT * (23 fichiers)
2. Cache applicatif (APCu/Redis)
3. Optimisation getVotingCategoriesForUser()
4. Pagination (nominees, results)
5. Minification CSS/JS
6. Compression gzip Apache
7. Lazy loading images

Gains :

- Temps de chargement : -60% (1.8s → 0.7s)
- Requêtes SQL : -70% (10 → 3 par page)
- Bande passante : -65% (487 KB → 170 KB)

6. SYNTHÈSE GLOBALE

Axe 3 : Robustesse (Priorité P2)

Criticité : NÉCESSAIRE pour maintenabilité
Actions :

1. Migration vers Composer + PSR-4
2. Refonte routing (Front Controller)
3. Suppression logique métier BDD
4. Uniformisation langue (français → anglais)
5. Suppression interfaces contrôleurs
6. URLs dynamiques (BASE_URL)
7. Tests PHPUnit (couverture >70%)

Gains :

- Maintenabilité : +80%
- Temps d'onboarding : -60% (15h → 6h)
- Risque de régression : -90%

Axe 4 : Conformité (Priorité P3)

Criticité : OBLIGATOIRE pour mise en production
Actions :

1. Accessibilité RGAA niveau AA
2. Conformité RGPD complète
3. Documentation RGPD (registre, PIA)
4. Droit à l'oubli implémenté

6. SYNTHÈSE GLOBALE

L'audit de l'application Social Media Awards révèle une base techniquement fonctionnelle mais présentant plusieurs vulnérabilités critiques et beaucoup de points d'amélioration majeurs.

Les points forts (Bcrypt, requêtes préparées, OPcache) témoignent d'une compréhension des bonnes pratiques de base. Cependant, l'absence de .env, la vulnérabilité RCE sur les uploads et l'absence de protection CSRF rendent l'application non déployable en production dans son état actuel.

Le plan d'action proposé sur 85 heures (binôme) permettra de :

- Corriger toutes les vulnérabilités critiques (P0-P1)
- Améliorer les performances
- Moderniser l'architecture (Composer, Controller, (Framework Symfony))
- Atteindre une conformité WCAG AA et RGPD

La containerisation Docker facilitera le déploiement et la collaboration. Les tests automatisés garantiront la non-régression.

Estimation de valeur client : $85h \times 65€ = 5\,525€$ HT

Limites de l'audit

Cet audit a été réalisé dans un temps limité et sur un périmètre défini. Les tests ont été effectués en environnement local (WAMP/localhost) : les performances peuvent différer en production (serveur, réseau, cache, configuration).

L'analyse sécurité repose surtout sur revue de code et vérifications ciblées ; elle ne remplace pas un pentest complet (tests d'intrusion) sur un environnement proche de la production.

Les aspects RGPD et accessibilité (WCAG/RGAA) ont été abordés au niveau bonnes pratiques, sans audit juridique/accessibilité exhaustif.

6. SYNTHÈSE GLOBALE

L'audit de l'application Social Media Awards révèle une base techniquement fonctionnelle mais présentant plusieurs vulnérabilités critiques et beaucoup de points d'amélioration majeurs.

Les points forts (Bcrypt, requêtes préparées, OPcache) témoignent d'une compréhension des bonnes pratiques de base. Cependant, l'absence de .env, la vulnérabilité RCE sur les uploads et l'absence de protection CSRF rendent l'application non déployable en production dans son état actuel.

Le plan d'action proposé sur 85 heures (binôme) permettra de :

- Corriger toutes les vulnérabilités critiques (P0-P1)
- Améliorer les performances
- Moderniser l'architecture (Composer, Controller, (Framework Symfony))
- Atteindre une conformité WCAG AA et RGPD

La containerisation Docker facilitera le déploiement et la collaboration. Les tests automatisés garantiront la non-régression.

Estimation de valeur client : $85h \times 65\text{€} = 5\,525\text{€ HT}$